Ανάλυση Συσχέτισης Κατανάλωσης Ισχύος (Correlation Power Analysis – CPA) στον Αλγόριθμο AES-128

1. Σκοπός

Σκοπός του εργαστηρίου είναι να γίνει κατανοητό πώς ένας θεωρητικά ασφαλής κρυπτογραφικός αλγόριθμος, όπως ο **AES-128**, μπορεί να διαρρεύσει μυστική πληροφορία όταν υλοποιείται σε πραγματικό υλικό.

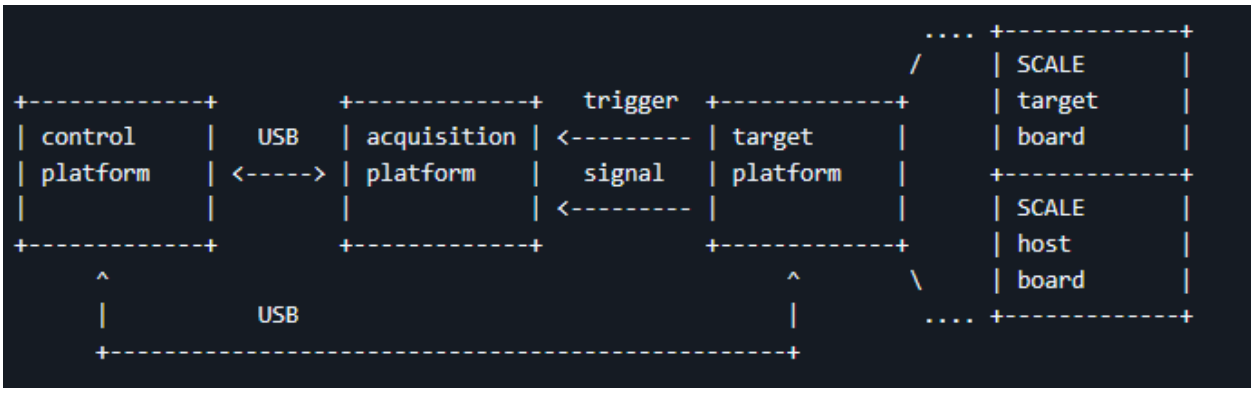
Συγκεκριμένα:

- Χρησιμοποιούνται **προκαταγεγραμμένα ίχνη κατανάλωσης ισχύος (power traces)** από υλοποίηση AES-128 σε μικροελεγκτή **ATmega328P**.
- Πραγματοποιείται **Correlation Power Analysis (CPA)** για την ανάκτηση **ενός byte του μυστικού κλειδιού**.

Το κλειδί για το εργαστήριο (για σκοπούς επαλήθευσης) είναι:

key_hex = "2B7E151628AED2A6ABF7158809CF4F3C"

Θα χρησιμοποιηθούν power-consumption traces (ίχνη πλευρικού καναλιού κρυπτογραφήσεων AES-128), που συλλέχθηκε από τον μικροελεγκτή **ATmega328p** χρησιμοποιώντας Picoscope 2206B όπως φαίνεται στο παρακάτω σχήμα (https://github.com/danpage/scale-hw)



Τα δεδομένα προέρχονται από την ιστοσελίδα https://github.com/danpage/scale-data?tab=readme-ov-file, και αφορούν την εκτέλεση της κρυπτογράφησης AES-128 σε μια συγκεκριμένη πλακέτα. Η υλοποίηση βασίζεται περίπου στο FIPS-197 [Τμήμα 6.4, 1] ή στις

σχετικές αναφορές που παραθέτει. Αυτό σημαίνει ότι χρησιμοποιεί έναν 8-bit δίαυλο δεδομένων και μικρούς προ-υπολογισμένους πίνακες για να υλοποιεί τις λειτουργίες **S-box** και **xtime**.

- **S-box:**
  Πρόκειται για έναν προ-υπολογισμένο πίνακα αντικατάστασης (substitution box) που χρησιμοποιείται στο AES για να αντικαθιστά κάθε byte του μηνύματος με ένα άλλο byte. Σκοπός του είναι να αυξήσει την ασφάλεια της κρυπτογράφησης και να αποσυνδέσει τα δεδομένα, ώστε να γίνει πιο δύσκολη η αποκρυπτογράφηση χωρίς το κλειδί. Η χρήση ενός πίνακα lookup επιτρέπει την γρήγορη εκτέλεση των αντικαταστάσεων χωρίς να χρειάζεται κάθε φορά να γίνονται μαθηματικοί υπολογισμοί.
- ***xtime:***
  Είναι μια λειτουργία πολλαπλασιασμού ενός byte με 2 μέσα στο πεδίο GF(2^8), που χρησιμοποιείται για την ανάμιξη των bytes στο AES (MixColumns). Ο στόχος της είναι να προσθέσει πολυπλοκότητα στην κρυπτογράφηση και να διασφαλίσει ότι τα δεδομένα διαχέονται σωστά σε όλο το μήνυμα. Όπως και με το S-box, χρησιμοποιούνται συνήθως προ-υπολογισμένοι πίνακες για να εκτελείται η λειτουργία γρήγορα και αποδοτικά.

Αντικειμενικοί στόχοι :

• **Ορισμός και επεξήγηση των επιθέσεων πλευρικού καναλιού (Side Channel Attacks)**, δηλαδή επιθέσεων που εκμεταλλεύονται φυσικές διαρροές ενός συστήματος, όπως η κατανάλωση ισχύος ή ο χρόνος εκτέλεσης, αντί για αδυναμίες του ίδιου του αλγορίθμου.

• **Κατανόηση του λόγου για τον οποίο η κατανάλωση ισχύος διαρρέει πληροφορία**, λόγω της εξάρτησής της από τα δεδομένα και τις ενδιάμεσες τιμές που επεξεργάζεται το κρυπτογραφικό σύστημα.

• **Εφαρμογή μοντέλου διαρροής** για την πρόβλεψη της κατανάλωσης ισχύος, βασισμένου σε υποθέσεις σχετικά με τη συσχέτιση μεταξύ επεξεργαζόμενων δεδομένων και παρατηρούμενης ισχύος.

• **Υλοποίηση επίθεσης CPA (Correlation Power Analysis) σε Python**, με στόχο την ανάλυση μετρήσεων κατανάλωσης ισχύος και την εξαγωγή πληροφορίας για το μυστικό κλειδί.

• **Ερμηνεία των αποτελεσμάτων συσχέτισης** ώστε να επιτυγχάνεται η ανάκτηση ενός byte του κλειδιού μέσω στατιστικής ανάλυσης.

• **Τεκμηρίωση της σημασίας της ασφαλούς υλοποίησης κρυπτογραφικών αλγορίθμων**, αναδεικνύοντας ότι η ασφάλεια δεν εξαρτάται μόνο από τον αλγόριθμο, αλλά και από τον τρόπο υλοποίησής του στο υλικό ή στο λογισμικό.

2. Θεωρητικό Υπόβαθρο

2.1 Επιθέσεις Πλευρικού Καναλιού

Η κρυπτογραφία αποδεικνύει ασφάλεια σε αλγοριθμικό επίπεδο, όμως οι φυσικές συσκευές:

- Καταναλώνουν ισχύ
- Εκτελούν εντολές σειριακά
- Εμφανίζουν ενεργειακές μεταβολές ανάλογα με τα δεδομένα

Σημείο: Οι επιθέσεις πλευρικού καναλιού εκμεταλλεύονται **τον τρόπο εκτέλεσης** και όχι **το αποτέλεσμα των υπολογισμών**.

2.2 Known-Key Analysis (Ανάλυση Γνωστού Κλειδιού)

Στο εργαστήριο:

- Το κλειδί κατά τη συλλογή των ιχνών είναι γνωστό
- Το κλειδί **δεν χρησιμοποιείται κατά την επίθεση**
- Χρησιμοποιείται **μόνο στο τέλος** για επιβεβαίωση σωστής ανάκτησης

Στόχοι:

- Εκπαίδευση και επικύρωση
- Αποσφαλμάτωση υλοποιήσεων
- Επαλήθευση μοντέλων διαρροής

Το AES-128 κλειδί:

key_hex = "2B7E151628AED2A6ABF7158809CF4F3C"

2.3 Unknown-Key Analysis (Πραγματικές Επιθέσεις)

- Το κλειδί είναι άγνωστο
- Η επιτυχία βασίζεται αποκλειστικά σε στατιστικά στοιχεία
- Η διαδικασία CPA παραμένει ίδια

2.4 Γιατί η Κατανάλωση Ισχύος Διαρρέει Πληροφορία

Σε μικροελεγκτές CMOS:

- Η μετάβαση bit 0 → 1 καταναλώνει ενέργεια
- Περισσότερες μεταβάσεις → υψηλότερη ισχύς
- Δεδομένα επηρεάζουν τα πρότυπα μεταβάσεων

Υπόδειξη: Τα ίχνη ισχύος είναι θορυβώδη αλλά όχι τυχαία.

2.5 Στατιστικός Χαρακτήρας του CPA

- Ένα μεμονωμένο ίχνος περιέχει θόρυβο και δεν αποκαλύπτει το κλειδί
- CPA βασίζεται στη συστηματική συσχέτιση σωστών υποθέσεων κλειδιού
- Οι λανθασμένες υποθέσεις ταιριάζουν τυχαία
- Η στατιστική επεξεργασία ενισχύει μικρά αλλά συνεπή σήματα

Η ανάλυση **CPA** είναι μια τεχνική **side-channel attack** (επίθεσης μέσω δευτερευουσών πληροφοριών) που χρησιμοποιείται κυρίως για να «σπάσει» κρυπτογραφικούς αλγορίθμους, όπως το **AES**, ανιχνεύοντας σχέσεις μεταξύ **καταναλισκόμενης ισχύος** (power consumption) ενός συστήματος και των δεδομένων που επεξεργάζεται.

Περιλαμβάνει:

- **Μέτρηση κατανάλωσης ισχύος**:

Κατά την εκτέλεση ενός κρυπτογραφικού αλγορίθμου, η συσκευή (π.χ. smart card ή μικροελεγκτής) καταναλώνει ηλεκτρική ενέργεια, η οποία εξαρτάται από τις εσωτερικές τιμές που επεξεργάζεται, όπως τα bytes του κλειδιού και του plaintext.

- **Υπόθεση μοντέλου κατανάλωσης ισχύος**:

Υιοθετείται ένα μοντέλο κατανάλωσης ισχύος, συνήθως το μοντέλο Hamming Weight (αριθμός bit με τιμή 1) ή το Hamming Distance (αριθμός bit που μεταβάλλονται μεταξύ δύο καταστάσεων).

- **Υπολογισμός υποθετικών τιμών ισχύος**:

Για κάθε πιθανή τιμή του κλειδιού ή μέρους αυτού, και με βάση τα δεδομένα εισόδου, υπολογίζονται οι υποθετικές τιμές κατανάλωσης ισχύος σύμφωνα με το επιλεγμένο μοντέλο.

- **Συσχέτιση πραγματικών και υποθετικών μετρήσεων**:

Υπολογίζεται ο συντελεστής συσχέτισης, συνήθως ο συντελεστής Pearson, μεταξύ των πραγματικών μετρήσεων κατανάλωσης ισχύος και των υποθετικών τιμών για κάθε πιθανό υποκλειδί.

- **Αναγνώριση του σωστού κλειδιού**:

Η τιμή του κλειδιού που παρουσιάζει τη μεγαλύτερη συσχέτιση θεωρείται ως η επικρατέστερη υποψήφια για το σωστό κλειδί.

2.6 Μοντέλο Hamming Weight

- Το **Hamming Weight (HW)** = αριθμός bits με τιμή 1
- Χρησιμοποιείται ευρέως γιατί συσχετίζεται με κατανάλωση ισχύος
- Αποτελεί απλοποιημένο μοντέλο, όχι τέλεια αναπαράσταση φυσικών φαινομένων

---

3. Dataset

Αρχείο: ***atmega328p.hdf5***

Περιεχόμενα:

- trace: δείγματα κατανάλωσης ισχύος
- m: plaintexts
- c: ciphertexts

Περιορισμοί:

- Μην χρησιμοποιείτε το κλειδί κατά τη διάρκεια της επίθεσης
- Χρησιμοποιείται μόνο για επαλήθευση στο τέλος

Το αρχείο θα το βρείτε στην ιστοσελίδα (απαιτείται να το αποθηκεύσετε στον υπολογιστή σας και να το αποσυμπιέσετε):

https://github.com/danpage/scale-data/blob/master/data/scale/known/atmega328p.hdf5.gz

4. Ζητήματα

Ζήτημα #1 – Φόρτωση και Επιθεώρηση Dataset

- Εξετάστε τη δομή των πραγματικών δεδομένων
- Χρησιμοποιείστε NumPy arrays για υπολογισμούς
- Προσέξτε τη διαφορά **αριθμού ιχνών** και **δείγματος ανά ίχνος**

Υπόδειξη: Πολλαπλά ίχνη (~χιλιάδες) και samples ανά ίχνος (~χιλιάδες)

<u>Ερωτήματα:</u>

1. Ποια είναι η δομή του dataset atmega328p.hdf5;
2. Πόσα ίχνη (traces) περιέχει το dataset;
3. Πόσα δείγματα (samples) έχει κάθε ίχνος;
4. Ποια είναι η διάσταση των plaintexts και των ciphertexts;
5. Γιατί είναι σημαντικό να διακρίνουμε τον αριθμό ιχνών από τον αριθμό δειγμάτων ανά ίχνος;

Ζήτημα #2 – Οπτικοποίηση Ιχνών

- Ελέγξτε ευθυγράμμιση ιχνών
- Εντοπίστε θορυβώδη διαρροή
- Οπτικοποιήστε 5–10 ίχνη πρώτα με διαφάνεια (alpha <1)

Υπόδειξη: Ένα μόνο ίχνος δεν αποκαλύπτει το κλειδί → απαιτείται στατιστική ανάλυση

<u>Ερωτήματα:</u>

1. Πώς μπορείτε να επαληθεύσετε ότι τα ίχνη είναι χρονικά ευθυγραμμισμένα;
2. Τι παρατηρείτε όσον αφορά το θόρυβο στα πρώτα 5–10 ίχνη;
3. Γιατί ένα μόνο ίχνος δεν αρκεί για την ανάκτηση του κλειδιού;
4. Ποιο είναι το πλεονέκτημα της στατιστικής ανάλυσης σε αυτή την περίπτωση;

Ζήτημα #3 – Επιλογή Στόχου AES

- Επιλέξτε byte που επηρεάζεται από plaintext και key

- Επεξεργάζεται νωρίς και παράγει ισχυρή διαρροή
- Συνήθης στόχος: **S-box output**

v = SBox(plaintext_byte ⊕ key_byte)

<u>Ερωτήματα:</u>

1. Ποιο byte του AES επιλέγετε ως στόχο και γιατί;
2. Τι ρόλο παίζει το XOR μεταξύ plaintext byte και key byte στην επίθεση;
3. Γιατί η έξοδος της S-box θεωρείται κλασικός στόχος σε CPA;
4. Σε ποιον γύρο του AES γίνεται η επεξεργασία του επιλεγμένου byte;

Ζήτημα #4 – Υλοποίηση Μοντέλου Διαρροής

- Μετατρέψτε τιμές δεδομένων σε υποθετική ισχύ
- HW χρησιμοποιείται (0–8)
- Έλεγχος με γνωστές τιμές

<u>Ερωτήματα:</u>

1. Τι είναι το Hamming Weight (HW) και πώς σχετίζεται με την κατανάλωση ισχύος;
2. Πώς μετατρέπεται μια τιμή δεδομένων σε υποθετική ισχύ χρησιμοποιώντας HW;
3. Πώς μπορείτε να ελέγξετε ότι το μοντέλο HW λειτουργεί σωστά με γνωστές τιμές;

5. Παραδοτέο

- Αναφορά σε Word ή PDF που περιλαμβάνει:
  - Απαντήσεις στα ερωτήματα
  - Γραφικές Παραστάσεις, όπου ζητούνται
  - Κώδικα Python ή άλλη γλώσσα που χρησιμοποιήσατε για τις λύσεις
  - Η αναφορά πρέπει να περιλαμβάνει στο τέλος ένα σύντομο συμπέρασμα (5–10 γραμμές), που να εξηγείτε με δικά σας λόγια γιατί η CPA αποτελεί χαρακτηριστικό παράδειγμα του χάσματος μεταξύ θεωρητικής και πρακτικής ασφάλειας σε κρυπτογραφικά συστήματα.